

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA51 **COURSE NAME:** Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I Eddu Suchier/192524070 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: E. Suchier

Annexure A

Industry Problem-Solving Task

2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
- B. Design an automated key management mechanism (e.g., IKE-based)
- C. Propose a strategy for key renewal and revocation
- D. Evaluate scalability and fault tolerance

IPSec Key Management

1. Analyze Current SA Lifecycle Issues

The organization is facing expired and mismatched Security Associations (SAs), which can cause IPSec tunnels to fail or communication to be interrupted. Common problems include manual key configuration, inconsistent SA lifetimes, delayed key renewal, and improper synchronization between peers. These issues become more difficult to manage as the number of IPSec connections increases.

2. Automated Key Management Mechanism

The organization should implement IKEv2 (Internet Key Exchange version 2) for automated IPSec key management. IKEv2 allows two communicating devices to authenticate each other, negotiate encryption algorithms, and automatically establish Security Associations. It also generates session keys securely using Diffie-Hellman key exchange, eliminating the need for administrators to manually configure keys.

A centralized policy can define parameters such as encryption algorithms, authentication methods, Diffie-Hellman groups, and SA lifetimes. All IPSec gateways should follow the same policy to avoid configuration mismatches.

3. Key Renewal and Revocation Strategy

IKEv2 should automatically rekey SAs before they expire. For example, a new SA can be negotiated before the existing SA reaches its lifetime, allowing uninterrupted communication. Old SAs should be removed after successful rekeying.

If a key or device is compromised, its credentials should be revoked immediately. Certificates can be managed through a PKI (Public Key Infrastructure), using certificate revocation mechanisms such as CRLs or OCSP. Compromised credentials should also be replaced and affected SAs terminated.

4. Scalability and Fault Tolerance

For a large enterprise, IKEv2-based automated management is more scalable than manually configured keys because gateways can establish and renew SAs automatically. A centralized configuration and monitoring system can maintain consistent security policies across many gateways.

For fault tolerance, the organization should deploy redundant IPSec gateways and multiple IKE servers where appropriate, with automatic failover. Monitoring should detect failed tunnels, expired SAs, and authentication failures and trigger corrective actions.

Proposed Architecture

Enterprise Devices → IPSec Gateway → IKEv2 → Authentication/PKI → Automated SA Establishment → Encrypted IPSec Tunnel

Final Recommendation

The organization should migrate from manual key management to IKEv2 with centralized security policies and PKI-based authentication. Automated SA establishment, proactive rekeying, certificate-based revocation, centralized monitoring, and redundant gateways will reduce key mismatches and downtime while providing a scalable and fault-tolerant IPSec infrastructure.

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification
- D. Design a high-level implementation workflow

PGP vs S/MIME

1. Comparison in Real-World Deployment

Factor	PGP	S/MIME
Usability	More complex for non-technical users	Easier for enterprise users
Key management	Users manage public/private keys	Certificates are managed through PKI
Trust model	Web of Trust	Hierarchical Certificate Authority (CA)
Scalability	More difficult for large organizations	Highly suitable for enterprises
Enterprise integration	Requires additional tools/configuration	Integrates well with corporate email systems
Administration	More decentralized	Centralized management is easier

2. Key Management and Trust Models

PGP uses a Web of Trust, where users verify and sign each other's public keys. This provides flexibility but can become difficult to manage when thousands of employees are involved.

S/MIME uses digital certificates issued by trusted Certificate Authorities (CAs). The organization can centrally issue, renew, revoke, and manage employee certificates through a PKI (Public Key Infrastructure). This makes S/MIME more suitable for enterprise environments.

3. Recommendation

For the financial services company, S/MIME is recommended. Since the company handles sensitive financial transactions, centralized certificate management, strong authentication, and integration with enterprise email infrastructure are important. S/MIME provides encryption, digital signatures, message integrity, and sender authentication while reducing the burden of individual key management.

PGP can be appropriate for individuals or organizations that require decentralized control, but S/MIME is generally more practical for a large enterprise with centralized IT administration.

4. High-Level Implementation Workflow

Step 1: Establish an enterprise PKI and Certificate Authority (CA).

Step 2: Issue an S/MIME certificate and key pair to each authorized employee.

Step 3: Configure the organization's email clients and servers to support S/MIME.

Step 4: When sending a sensitive email, the sender digitally signs the message and encrypts it using the recipient's certificate.

Step 5: The recipient's email client verifies the digital signature and decrypts the message using the recipient's private key.

Step 6: Continuously manage certificate renewal, revocation, backup, and monitoring.

Conclusion

For a financial services enterprise, S/MIME is the preferred solution because it offers centralized key management, a well-established PKI trust model, easier

administration, and strong integration with enterprise email systems. This makes it more scalable and manageable for secure business communication.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding ; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation